

 F3-SW-01

 SOFTWARE + MACHINE LEARNING

VulnGraph AI

SBOM-Based Dependency Risk Detection System

"From SBOMs to Intelligent Software Supply-Chain Risk"

TEAM

CyberGuard Team

CONTRIBUTORS

Lidiya (ML/Sec) • DevSecOps Lead • Core Team

⚠ Hidden Dependency Vulnerabilities

The Software Supply Chain Blindspot

Modern applications consist of 80%+ open-source dependencies. Security flaws are rarely in your direct code—they lurk deep inside nested packages.



Transitive Depth

Vulnerabilities buried 3–7 levels down.



Patch Lag

Outdated libraries left unpatched for years.

DEPENDENCY HIERARCHY



Application (My-Service)

DIRECT



Express v4.18.2

Depth 1



Body-Parser v1.19.0

Depth 2



Vulnerable-Pkg v1.0.1

CVE-2024-XXXX



Axios v1.6.0

Depth 1

Legacy Scanners vs. VulnGraph AI

✖ Traditional Vulnerability Scanners



Alert Fatigue

Dump 100+ raw unprioritized CVE alerts on developers.



Zero Graph Context

Treats deep transitive packages same as direct imports.



Over-reliance on CVSS

Ignores real-world EPSS exploit probability.

✔ VulnGraph AI Platform



Graph Reachability

Traces exact dependency paths & exposure depth.



ML Risk Prioritization

Combines EPSS, patch lag, and structural impact.



Top Actionable Fixes

Filters 100 alerts down to the 5 critical security actions.

Introducing VulnGraph AI



STEP 1

Ingest SBOM

Parses standardized CycloneDX & SPDX manifests instantly.

STEP 2

Graph Traversal

Builds relational dependency trees mapping transitive depth.



STEP 3

Threat Intel

Cross-references OSV, NVD, GitHub Advisories & EPSS scores.



STEP 4

ML Gate

Prioritizes exploits and blocks unsafe builds in CI/CD pipelines.

🎯 Core Mission: Don't just detect vulnerabilities—prioritize the vulnerabilities that actually matter.

End-to-End Workflow Pipeline



✓ Low Risk Outcome

Risk Score < 70 → CI/CD Pass → Automated Merge

PASS

✗ Critical Threat Outcome

Risk Score ≥ 80 → CI/CD Fail → PR Blocked + Alert

BLOCK

Multi-Ecosystem & SBOM Standards

Supported Ecosystems

JavaScript

npm • Bun • Yarn

Python

pip • PyPI • Poetry

EXTENSIBLE MODULAR ARCHITECTURE

Pluggable parsers ready for Maven, Gradle, Go, and Rust ecosystems.

Standard SBOM Formats

CycloneDX

OWASP Standard (v1.4 / v1.5 JSON)

SECURITY SPEC

SPDX

Linux Foundation Standard (v2.3)

ISO STANDARD

Tracing Transitive Dependencies

Uncovering Deep Hidden Risks

Direct scanning only checks top-level requirements. VulnGraph AI recursively expands every node in the dependency graph to expose vulnerabilities deeply embedded in transitive chains.

Key Insight

Over 75% of critical supply-chain vulnerabilities enter through level-2+ transitive dependencies.



Multi-Source Vulnerability Intelligence

Database Ingestion Sources

Continuous synchronization with global vulnerability repositories:

OSV.DEV

NVD / CVE

GITHUB SECURITY ADVISORIES

EPSS FIRST.ORG

EPSS Integration

Exploit Prediction Scoring System predicts real-world exploitation probability within 30 days.

CORRELATED SECURITY CONTEXT

Package: **lodash**

Current Version: 4.17.15 → Fixed: 4.17.21

CVSS Score:

7.4 (High)

Patch Release Lag:

1,800+ Days

EPSS Probability:

0.89 (89% Exploit)

Known Exploit:

Public PoC Available

Context-Aware Risk Scoring Model

MATHEMATICAL FORMULATION

$$\text{Risk Score} = \text{Severity}_{\text{CVSS}} \times \text{EPSS} \times (1 + \text{Patch Lag Factor}) \times \frac{1}{\sqrt{\text{Depth}}}$$

90 – 100

CRITICAL

Immediate CI/CD block; Active exploit in wild.

70 – 89

HIGH

High exploitability or direct dependency depth.

40 – 69

MEDIUM

Moderate risk; Scheduled patch cycle required.

0 – 39

LOW

Low exploit probability; Informational finding.

ML-Powered Risk Prioritization

Feature Matrix Inputs

- **Static Factors:** CVSS Base Score, Dependency Depth.
- **Dynamic Threat:** EPSS Prob, Known Exploit (KEV).
- **Temporal Metrics:** Patch Age, Version Distance.
- **Graph Topography:** Number of Dependents, Direct Reachability.

Classifier Architecture

XGBoost / Random Forest Classifier

Trained on historical vulnerability exploit patterns and GitHub Advisory data to classify real-world severity likelihood.

Prediction Output: Risk Probability = 0.94 → **CRITICAL**

▼ High-Impact Alert Prioritization

📢 Traditional Scanners (100+ Findings)

Creates developer fatigue with endless flat lists of CVSS 7.0+ vulnerabilities.

```
[CVE-2021-3711] high - openssl  
[CVE-2022-23305] high - log4j-core  
[CVE-2020-19909] high - tar  
... 97 more unprioritized alerts
```

✓ VulnGraph AI (Top Actionable Fixes)

Distills 100 alerts into the top critical vulnerabilities posing real exploit threat.

lodash @ 4.17.15

Score: 96

axios @ 0.21.1

Score: 91

express @ 4.16.0

Score: 82

Automated Remediation Engine

CRITICAL THREAT

Depth: 3 (Transitive)

lodash @ 4.17.15

CVE-2021-23337 • Prototype Pollution

Dependency Chain Path:

App → web-service → async-pkg → lodash

Actionable Remediation

Target patch version identified with zero breaking changes.

Auto-Fix Command

```
npm install lodash@4.17.21 --save-exact
```

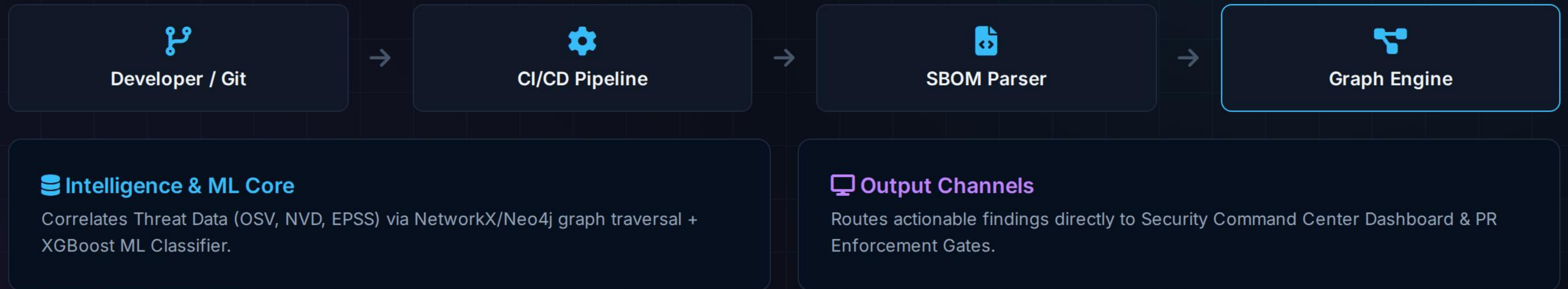
 Automatically generates Pull Request with targeted lockfile update.

Automated CI/CD Security Gate

.GITHUB/WORKFLOWS/SECURITY.YML

```
- name: VulnGraph AI Risk Scan uses: vulngraph-ai/scanner@v1 with: sbom-path: 'sbom.json' risk-threshold: 80 fail-on-critical: true
```

Production System Architecture



Technology Stack



Frontend

React • Tailwind CSS

Recharts data visualization suite for graph UI.



Backend

FastAPI • Python

PostgreSQL database with NetworkX graph processing.



Machine Learning

Scikit-Learn • XGBoost

Predictive risk scoring & exploit classification models.



DevSecOps

Docker • GitHub Actions

OSV.dev, CVE/NVD, EPSS data integrations.

Security Command Center

Real-Time Visibility Dashboard

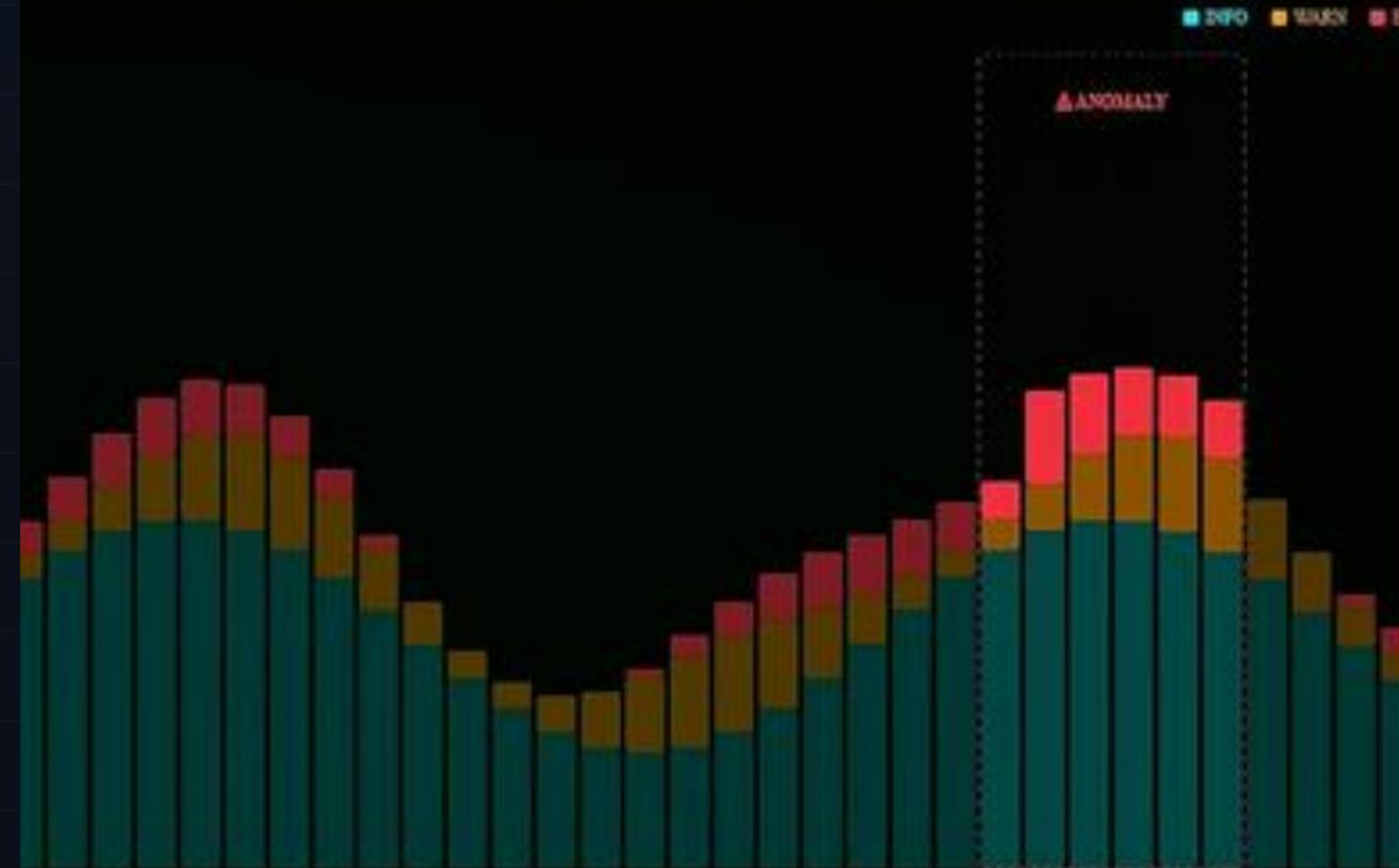
Centralized enterprise console providing immediate risk posture visibility across all repositories.

BUILD STATUS

Reason: 3 Critical unpatched dependencies detected in PR #142.

X BLOCKED

PIPELINE MONITOR



Core Differentiators



1. SBOM-First Design

Native support for CycloneDX and SPDX standardizing software inventory.



2. Transitive Graph Intel

Exposes deeply nested vulnerabilities hidden multiple levels down.



3. ML Risk Prioritization

Predicts real-world exploitation probability beyond raw CVSS scores.

Less noise. Better prioritization. Faster remediation.

Implementation Roadmap

PHASE 1

MVP Core

SBOM Ingestion, npm/Python parsing, OSV vulnerability matching.

PHASE 2

Intelligence

EPSS probability integration, ML classifier model, remediation engine.

PHASE 3

DevSecOps

GitHub Actions plugin, PR automated checks & merge blocking guardrails.

PHASE 4

Scale (Roadmap)

Maven, Go, Rust ecosystems + Enterprise SSO & Compliance Reporting.

THE FUTURE OF SUPPLY-CHAIN SECURITY

**“Your application is only as secure as its
weakest dependency.”**

VulnGraph AI transforms complex dependency graphs into prioritized, actionable security decisions.

Detect



Prioritize



Remediate



Prevent



Thank You!

VulnGraph AI — Questions & Discussion

Repository
`github.com/vulngraph-ai`

Live Demo
`demo.vulngraph.ai`

Image Sources



https://png.pngtree.com/background/20250715/original/pngtree-abstract-glowing-digital-network-graph-with-data-lines-and-nodes-picture-image_16729180.jpg

Source: [pngtree.com](https://png.pngtree.com/)



<https://static.vecteezy.com/system/resources/thumbnails/080/697/165/large/a-professional-realtime-observability-dashboard-displaying-dynamic-telemetry-data-streams-and-system-anomaly-detection-within-a-futuristic-dark-mode-cyber-security-operational-center-interface-screen-video.jpg>

Source: www.vecteezy.com